
CLOUD COMPUTING AND SECURITY

Case Study Analysis

1. Problem Statement

A mid-sized government hospital, City General Hospital, manages the Electronic Health Records (EHR) of over 2,00,000 patients. The hospital recently migrated its entire patient data infrastructure to a public cloud platform (AWS). This migration was done to reduce IT costs and improve data accessibility across multiple departments and branch clinics.

Core Problem

The hospital's cloud-hosted patient records are vulnerable to unauthorized access, data breaches, and non-compliance with healthcare data protection regulations (such as HIPAA and India's DPDP Act 2023). Sensitive information — including diagnoses, prescriptions, insurance data, and personal identifiers — is at risk of exposure due to inadequate cloud security controls.

Key risks identified:

- Patient data stored in unencrypted S3 buckets, accessible without authentication
- No Identity and Access Management (IAM) policies restricting staff data access
- Absence of audit logging and monitoring for suspicious activities
- Third-party vendor integrations lacking security review
- No disaster recovery or data backup plan in place

2. Problem Understanding

In simple terms, the hospital moved its patient records to the cloud to make them easier to access — but forgot to lock the door. Cloud systems are powerful but come with shared responsibility: the cloud provider (AWS) secures the infrastructure, but the hospital must secure its own data and applications.

The hospital assumed that moving to the cloud automatically meant the data was secure. This is a very common misconception. In reality:

- Cloud platforms are secure by design, but misconfiguration by users is the #1 cause of breaches
- Patient records (PHI – Protected Health Information) are among the most valuable data on the dark web
- A single breach can affect thousands of patients, lead to regulatory fines, and damage public trust

This is fundamentally a Cloud Security Governance problem — covering three dimensions:

Dimension	What is Missing
Confidentiality	Data is not encrypted; unauthorized users may access records
Integrity	No controls to detect unauthorized modification of records
Availability	No backup strategy; data could be lost due to ransomware or failure
Compliance	Violation of HIPAA / DPDP Act 2023 regulations
Accountability	No audit trails to track who accessed or modified what

3. Cause of the Problem

The root causes of this security gap can be classified under technical, administrative, and procedural failures:

A) Technical Causes

- Misconfigured cloud storage (S3 buckets set to public access)
- Lack of encryption at rest and in transit (no TLS/SSL, no AES-256 encryption)
- Absence of Multi-Factor Authentication (MFA) for admin accounts
- No Virtual Private Cloud (VPC) or network segmentation to isolate sensitive data
- Outdated APIs used by third-party labs and pharmacies without security review

B) Administrative / Policy Causes

- No formal Cloud Security Policy or Risk Assessment conducted before migration
- Lack of Role-Based Access Control (RBAC): all staff had blanket access to all records
- No Security Awareness Training for hospital IT and administrative staff
- Absence of a Data Protection Officer (DPO) or CISO role

C) Procedural Causes

- No incident response plan for data breach scenarios
- Penetration testing and vulnerability assessments never performed
- Cloud vendor SLAs (Service Level Agreements) did not include security clauses
- No regular security audits or compliance checks scheduled

Root Cause Summary
The hospital treated cloud migration as a purely technical/infrastructure task. Security was an afterthought, not a built-in design principle. The Shared Responsibility Model of cloud security was not understood or implemented, leaving critical patient data exposed.

4. Solution

The solution requires a multi-layered security framework — often called Defense in Depth — applied across people, processes, and technology.

Layer 1: Data Security (Encrypt Everything)

- Enable AES-256 encryption for all data at rest in S3, RDS databases, and EBS volumes
- Enforce TLS 1.2/1.3 for all data in transit between hospital systems and cloud
- Use AWS Key Management Service (KMS) for centralized key management
- Apply data masking / tokenization for non-clinical staff viewing records

Layer 2: Identity & Access Management (IAM)

- Implement Role-Based Access Control (RBAC): doctors see full records, nurses see limited data, billing staff see financial data only
- Enforce Multi-Factor Authentication (MFA) for all accounts, especially admin
- Apply the Principle of Least Privilege — grant only the minimum access needed
- Use AWS IAM policies with condition keys (time-based, IP-based access)

Layer 3: Network Security

- Deploy a Virtual Private Cloud (VPC) with public/private subnet separation
- Use Security Groups and Network ACLs to restrict inbound/outbound traffic
- Enable AWS WAF (Web Application Firewall) to block injection and XSS attacks
- Set up VPN / Direct Connect for secure hospital-to-cloud communication

Layer 4: Monitoring & Incident Response

- Enable AWS CloudTrail for full audit logging of every API call and data access
- Use AWS CloudWatch + GuardDuty for real-time anomaly detection and alerting
- Set up SIEM (Security Information & Event Management) for centralized log analysis
- Develop and rehearse an Incident Response Plan (IRP) for breach scenarios

Layer 5: Compliance & Governance

- Conduct a HIPAA / DPDP Act 2023 compliance audit before go-live
- Appoint a Data Protection Officer (DPO) responsible for data governance
- Perform quarterly penetration testing and annual third-party security audits
- Train all staff on cloud security hygiene and phishing awareness

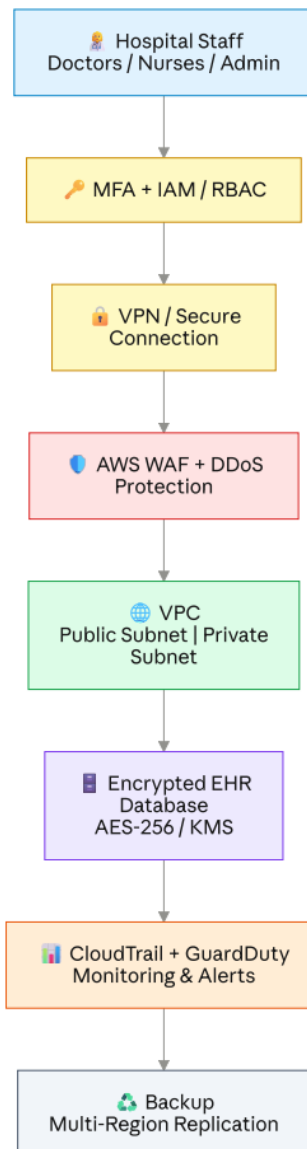
Layer 6: Backup & Disaster Recovery

- Implement automated daily backups with 30-day retention using AWS Backup
- Use multi-region replication to ensure data availability during outages
- Test disaster recovery procedures every 6 months (RTO < 4 hrs, RPO < 1 hr)

Security Control	AWS Service / Tool
Data Encryption	AWS KMS, S3 SSE, TLS/SSL

Access Management	AWS IAM, MFA, RBAC
Network Security	VPC, Security Groups, WAF
Monitoring & Audit	CloudTrail, GuardDuty, CloudWatch
Compliance	AWS Artifact, Config, Macie
Backup & Recovery	AWS Backup, S3 Cross-Region Replication

5. Diagram / Architecture (Cloud Security Layers)



Real-World Example: In 2019, Capital One suffered a major breach on AWS due to a misconfigured WAF. A hospital system following the above layered architecture would have detected and blocked such unauthorized access through GuardDuty alerts and strict IAM policies long before data exfiltration.

6. Conclusion

The case of City General Hospital illustrates that cloud migration, without a corresponding security strategy, creates dangerous vulnerabilities — especially for healthcare data that is both sensitive and legally protected.

The key takeaways from this case study are:

- The Cloud Shared Responsibility Model must be clearly understood: the cloud provider secures the platform; the customer secures the data
- Encryption, IAM, and network controls are non-negotiable for healthcare data
- Compliance with HIPAA and India's DPDP Act 2023 requires proactive governance — not reactive fixes
- Security must be integrated from Day 1 of any cloud project, not added later
- Continuous monitoring and regular audits are essential in a dynamic cloud environment

Final Recommendation

Adopt a Zero Trust Security Architecture: **'Never Trust, Always Verify.'** Every user, device, and application must authenticate and be authorized before accessing any patient data — regardless of location (inside or outside the hospital network).

By implementing the Defense in Depth framework across data, identity, network, monitoring, compliance, and backup layers, City General Hospital can ensure confidentiality, integrity, and availability (CIA Triad) of its cloud-hosted patient records — protecting both patient welfare and institutional reputation.
